

B-B-09 受講登録していない資格の教材詳細を直リンクで閲覧できてしまう

概要

受講生(student)が、自分が受講登録していない資格の教材詳細(Part / Chapter / Section)を、URLを直接指定すること(直リンク)で閲覧できてしまう。本来、受講生は自分が受講登録している資格の教材しか閲覧できないはずだが、登録外の資格の教材が露出する(IDOR)。

再現手順

前提: 受講生 A でログイン済み。受講生 A は資格 X に受講登録済みだが、資格 Y には未登録。資格 Y には公開済みの教材が存在する。

1. 受講生 A で、未登録の資格 Y に属する教材詳細(Part / Chapter / Section)の URL を直接開く
2. → 弾かれず、資格 Y の教材詳細が表示されてしまう
3. 受講登録済みの資格 X の教材は従来どおり表示される(対比用)

期待する結果

受講生が、自分が受講登録していない資格の教材詳細(Part / Chapter / Section)の URL に直接アクセスすると 403 が返る。受講登録している(受講中 / 合格)資格の教材のみ閲覧できる。

実際の結果

受講登録の有無を確認しないまま教材詳細が表示され、URL を知っていれば未登録資格の教材を直リンクで閲覧できてしまう。

メタ情報

項目	値
チケット ID	B-B-09
Feature 連番	content-management-04
Feature	content-management(受講生向け教材閲覧 / learning)

項目	値
種別	Bug
サブカテゴリ	認可・認証(IDOR)
難易度	Basic
依存チケット	(なし)